

Audit Purple Team Global (Infrastructures Windows et Linux)

Audit du Serveur Windows (Cible : Windows / Attaquant : Linux)

Partie 1.1 : Audit Réseau et Isolation (IPsec)

L'objectif est de vérifier que la machine Windows rejette le trafic non authentifié via Kerberos/IPsec.

1. Connectez-vous sur la machine **Linux**.
2. Exécutez un scan de ports ciblant les services d'administration Windows :
`nmap -Pn -p 135,445,3389,5985 <IP_WINDOWS>`

Résultat : L'état des ports doit être filtered. Le pare-feu Windows rejette silencieusement les paquets (Drop) car la machine Linux ne possède pas de ticket Kerberos valide pour établir le canal IPsec.

Partie 1.2 : Contrôle d'exécution (AppLocker et CLM)

L'objectif est de valider le blocage des charges utiles et la restriction de l'interpréteur PowerShell.

1. Connectez-vous sur la machine **Windows Server** avec le compte standard FORMATION\pirate.
2. Ouvrez une invite de commande cmd.exe.
3. Tentez de télécharger et d'exécuter un binaire non autorisé dans un dossier permissif :
`cd C:\Windows\Temp`
`certutil.exe -urlcache -split -f http://www.eicar.org/download/eicar.com.txt malware.exe`
`.\malware.exe`

Résultat : Un message d'erreur rouge indique que le programme est bloqué par la stratégie de groupe (AppLocker).

4. Lancez PowerShell et testez le mode de langage contraint (CLM) :
`powershell.exe -Command "$test = New-Object -TypeName System.IO.FileInfo -ArgumentList 'C:\Windows'"`

Résultat : PowerShell retourne une erreur interdisant l'instanciation de l'objet, confirmant l'activation du Constrained Language Mode.

Partie 1.3 : Protection Mémoire (Credential Guard et PPL)

L'objectif est de vérifier l'impossibilité d'extraire des identifiants en mémoire.

1. Sur la machine **Windows Server**, fermez la session standard et ouvrez une session avec le compte FORMATION\Administrateur.
2. Ouvrez le **Gestionnaire des tâches** (taskmgr.exe).
3. Allez dans l'onglet **Détails**.
4. Localisez le processus lsass.exe, faites un clic droit et sélectionnez **Créer un fichier de vidage**.

Résultat attendu : Une erreur "Accès refusé" s'affiche. Le noyau (PPL) et l'hyperviseur (VBS) bloquent l'accès à la mémoire.

Partie 1.4 : Traçabilité et Centralisation (SOC)

L'objectif est de vérifier que les alertes ont été transmises au collecteur.

1. Basculez sur la machine **Linux**.
2. Interrogez le journal Syslog pour vérifier la réception des logs d'exécution (Sysmon) :
`sudo grep -i "sysmon" /var/log/syslog | tail -n 20`
3. Interrogez le journal pour vérifier les blocages AppLocker :
`sudo grep -i "applocker" /var/log/syslog | tail -n 10`

Résultat attendu : Les événements doivent contenir les lignes de commande exactes exécutées lors de la Partie 1.2.

Audit du Bastion Linux

Partie 2.1 : Cloisonnement Réseau (UFW)

L'objectif est de vérifier que le pare-feu Linux filtre correctement les ports non légitimes.

1. Connectez-vous sur la machine **Windows Server**.
2. Ouvrez une console **PowerShell**.
3. Lancez un test de connexion sur un port non autorisé (ex: HTTP/80) :
`Test-NetConnection -ComputerName <IP_LINUX> -Port 80`
4. Testez le port d'administration légitime (SSH/22) :

Test-NetConnection -ComputerName <IP_LINUX> -Port 22

Résultat : Le test sur le port 80 échoue (TcpTestSucceeded : False). Le test sur le port 22 réussit.

Partie 2.2 : Hygiène Cryptographique (SSH)

L'objectif est de vérifier le rejet des algorithmes obsolètes (Downgrade Attack).

1. Sur la machine **Windows Server**, tentez une connexion SSH en forçant un chiffrement faible (ex: 3DES) :
`ssh -c 3des-cbc pirate@formation.local@<IP_LINUX>`

Résultat : La connexion est rejetée instantanément. Le client SSH affiche une erreur no matching cipher found, listant uniquement les algorithmes forts configurés (ex: chacha20, aes256-gcm).

Partie 2.3 : Identité et Modèle en Tiers (SSSD)

L'objectif est de vérifier que le filtre Active Directory bloque les comptes standards.

1. Sur la machine **Windows Server**, tentez de vous connecter en SSH avec un compte AD standard :
`ssh pirate@formation.local@<IP_LINUX>`

2. Saisissez le mot de passe AD du compte pirate.

Résultat : Accès refusé (Permission denied). Le démon SSSD vérifie l'appartenance aux groupes AD et rejette la connexion car l'utilisateur ne fait pas partie du groupe autorisé (ex: Admins Tier 0).

Partie 2.4 : Délégation et Élévation de privilèges (Sudoers)

L'objectif est de valider l'accès légitime et l'élévation des droits gérée par l'AD.

1. Sur la machine **Windows Server**, connectez-vous avec le compte Administrateur AD :
`ssh Administrateur@formation.local@<IP_LINUX>`
2. Une fois le shell ouvert, élevez les privilèges :
`sudo su -`
3. Saisissez le mot de passe AD de l'Administrateur.

Résultat attendu : La connexion est autorisée et l'élévation réussit (root@...). La configuration globale est validée.